COMPTIA PENTEST+ · PT0-003 V3.0 · STUDY GUIDE

Domain 4 — Attacks & Exploits

Every official objective (4.1–4.10) run through the **attack chain**: *what it is* → *tool* → *indicator* → *remediation*.

35% of the exam — the single largest domain

This guide follows CompTIA's official objective numbering exactly and applies one consistent structure to every attack — the **chain framework** first demonstrated on network attacks. Learn each attack as the same four links so nothing is a loose fact:

WHAT IT IS → TOOL → INDICATOR → REMEDIATION

- **What it is** — the mechanism in one line; understanding *why* it works is how you beat CompTIA's one-token-off distractors.
- **Tool** — what you'd run (recognition is enough for most items).
- **Indicator** — the evidence a PBQ shows you that proves it worked.
- **Remediation** — the fix; CompTIA frequently asks for this, not the attack.

Anchor 4.5 (web) to the **OWASP Top 10** and the rest to **MITRE ATT&CK**.

Confirmed weighting: per the official PT0-003 v3.0 objectives, Domain 4 (Attacks and Exploits) is **35%** — more than any other domain. Objectives 4.2–4.9 are all "perform … attacks using the appropriate tools"; 4.1 is prep/prioritization and 4.10 is scripting automation.

4.1 Analyze output to prioritize and prepare attacks

The "aim before you fire" objective — no tools run yet. You rank targets and pick capability. The high-yield piece is telling the four scoring/enumeration acronyms apart.

Concept	What it is	How you use it to prioritize
CVSS base score	0–10 severity rating of a vulnerability's intrinsic characteristics.	Rank by severity — but severity ≠ priority on its own.
CVE	A unique *identifier* for a specific known vulnerability.	Look up the exact flaw and find matching exploits.
CWE	A catalog of vulnerability *types/weaknesses* (e.g., CWE-89 = SQLi).	Understand the class of flaw and its typical fix.
EPSS	Probability a vuln will be *exploited in the wild*.	Combine with CVSS to prioritize likely-attacked targets.
High-value assets	Systems whose compromise yields the most impact (DCs, DBs).	Focus effort where it advances the engagement most.
EOL software / default configs / running services	Unsupported, unpatched, or out-of-box-weak systems.	Classic easy wins — prioritize these first.

Concept	What it is	How you use it to prioritize
Vulnerable encryption / defensive capabilities	Weak crypto; presence of EDR/WAF/IDS.	Pick exploits that work and evade the defenses present.
Capability selection	Tool + exploit selection/customization (code analysis), dependency check.	Match the exploit to the target; verify it won't break scope.
Documentation & scope	Attack path, low-level diagram, storyboard; label sensitive systems.	Plan the route and stay inside rules of engagement.

Distractor watch: CVE = which vulnerability, **CWE = what type**, **CVSS = how severe**, **EPSS = how likely to be exploited**. CompTIA loves swapping these.

4.2 Network attacks

Protocol and traffic attacks. High-yield theme: **poison/relay** — capture authentication and replay it.

Attack	What it is	Tool(s)	Indicator	Remediation
Default credentials	Devices/services left on vendor defaults.	Manual, Hydra	Login with known defaults.	Change defaults; enforce policy.
On-path (MITM)	Insert yourself between two hosts to read/modify traffic.	Ettercap, Bettercap, Responder	Duplicate MAC/ARP; captured traffic.	Dynamic ARP Inspection, encryption, signing.
Relay attack	Capture NTLM auth and relay it to another host — no cracking.	Responder + Impacket `ntlmrelayx`	Auth succeeds on relayed target.	SMB/LDAP signing; disable NTLM.
Certificate services (AD CS)	Abuse misconfigured templates (ESC1+) to mint auth certs.	Certify, Certipy	Cert issued for a privileged user.	Fix template permissions, enable manager approval.
Misconfigured services exploitation	Exploit weak/exposed service configs.	Metasploit, Nmap NSE	Unauthorized access/RCE.	Harden configs, patch, least privilege.
VLAN hopping	Reach other VLANs via switch spoofing (DTP) or double-tagging.	Yersinia, Scapy	Traffic on VLANs you shouldn't reach.	Disable DTP; don't use VLAN 1 native; lock trunks.
Multihomed hosts	Abuse a host with multiple NICs to bridge/pivot between networks.	Proxychains, sshuttle	Reach a segment only that host can.	Segment properly; restrict routing/forwarding.
Share enumeration	List SMB/NFS shares for access and data.	enum4linux, CrackMapExec, smbclient	Anonymous/writable shares listed.	Restrict shares, require auth + signing.
Packet crafting	Hand-build packets to test filters, spoof, or trigger conditions.	Scapy, hping3	Custom filter/response behavior.	Ingress/egress filtering, stateful inspection.

4.2 official tools: Metasploit · Netcat · Nmap (NSE) · Impacket · CrackMapExec (CME) · Wireshark/tcpdump · msfvenom · Responder · Hydra

> **Highest yield:** the `Responder → ntlmrelayx` chain, and **SMB signing** as the mitigation that breaks relay.

4.3 Authentication attacks

Two families: **guess/crack** credentials, or **reuse** captured secrets (pass-the-*, Kerberos, federation). Spraying beats brute force against lockout.

Attack	What it is	Tool(s)	Indicator	Remediation
Dictionary / brute-force	Try wordlist or all combinations against a login.	Hydra, Medusa	Success amid many failures.	Lockout, MFA, rate limiting.
Mask attack	Targeted cracking using a known password pattern.	Hashcat	Fast crack of patterned passwords.	Ban predictable patterns; long passphrases.
Password spraying	One common password across many users to dodge lockout.	CrackMapExec, Hydra	A few hits spread across accounts.	MFA, smart lockout, ban common passwords.
Credential stuffing	Replay breached user:pass pairs elsewhere.	Custom scripts	Logins using breach creds.	MFA, breached-password screening.
MFA fatigue	Spam push prompts until the user approves one.	Manual / scripted push	User approves an unrequested push.	Number matching, limit prompts, phishing-resistant MFA.
Pass-the-hash	Authenticate with the NTLM hash — no plaintext.	Impacket, CME, Mimikatz	Session using a hash.	Credential Guard, LAPS, limit admin reuse.
Pass-the-ticket	Reuse/forge Kerberos tickets for access.	Mimikatz, Rubeus	Auth via injected ticket.	Protect DCs, rotate krbtgt, monitor.
Pass-the-token	Steal and replay session/OAuth/access tokens.	Mimikatz, browser theft	Access without re-auth via a token.	Short token lifetimes, binding, revocation.
Kerberos attacks	Kerberoasting (SPN tickets) & AS-REP roasting (no-preauth accounts).	Rubeus, Impacket `GetUserSPNs` / `GetNPUsers`	Crackable TGS / AS-REP hashes.	Long service passwords, gMSA, require pre-auth, AES.
LDAP injection	Inject into LDAP queries to bypass auth or extract directory data.	Burp Suite	Auth bypass / unexpected directory results.	Input validation, parameterized LDAP filters.
OIDC attacks	Abuse OpenID Connect flows (redirect/token/nonce issues).	Burp Suite	Token accepted for another identity.	Validate redirect URIs, nonce, signatures.

Attack	What it is	Tool(s)	Indicator	Remediation
SAML attacks	Forge/alter SAML assertions ("golden SAML") to impersonate.	Burp, SAML Raider	Signed assertion for an arbitrary user.	Validate signatures, protect IdP signing keys.

4.3 official tools: CME · Responder · hashcat · John the Ripper · Hydra · BloodHound · Medusa · Burp Suite

> **Know the difference: Kerberoasting** needs valid domain creds and targets SPN service accounts; **AS-REP roasting** needs no creds and targets accounts with pre-auth disabled.

4.4 Host-based attacks

Turning a foothold into **SYSTEM/root**, harvesting secrets, and evading local defenses. Study Windows and Linux as parallels.

Attack	What it is	Tool(s)	Indicator	Remediation
Privilege escalation	Abuse misconfig/exploit to gain higher rights.	WinPEAS/LinPEAS, PowerUp, GTFOBins	Shell as SYSTEM/root.	Patch, least privilege, fix ACLs.
Unquoted service path	Space in an unquoted service path lets you plant a hijack exe.	WinPEAS, PowerUp	Service path with spaces + writable dir.	Quote service paths; fix permissions.
Credential dumping	Extract hashes/creds/tickets from memory or stores.	Mimikatz, Seatbelt	Plaintext/hashes/tickets recovered.	Credential Guard, restrict LSASS access.
Circumventing security tools	Disable/blind AV/EDR/logging.	LOLBins, custom loaders	EDR stopped; log gaps.	Tamper protection, offload logs to SIEM.
Payload obfuscation	Encode/pack payloads to evade signatures.	msfvenom, obfuscators	Payload runs undetected.	Behavioral EDR, allowlisting.
Process hollowing / injection	Run code inside a legit process's memory space.	Custom, C2 loaders	Trusted process shows unexpected behavior.	EDR memory scanning, protected processes.
Library injection	Force a process to load a malicious DLL/shared object.	ProcMon, custom	App loads attacker library.	Safe DLL search order, signed loads.
Shell / kiosk escape	Break out of a restricted shell (rbash) or locked-down kiosk to the OS.	GTFOBins	Full shell/OS access from a restricted UI.	Harden kiosk, remove escape binaries.
User-controlled access bypass	Manipulate client-side/user-controlled checks to gain access.	Manual	Access despite intended restriction.	Server-side enforcement of all checks.
Misconfigured endpoints	Weak local settings (perms, tasks, autoruns).	Seatbelt, WinPEAS	Abusable local misconfiguration.	Baseline/harden, monitor config.

Attack	What it is	Tool(s)	Indicator	Remediation
Log tampering	Clear/modify logs to hide activity.	`wevtutil`, LOLBins	Missing/altered log entries.	Real-time SIEM forwarding (Event ID 1102).

4.4 official tools: Mimikatz · Rubeus · Certify · Seatbelt · PowerShell/ISE · PsExec · Evil-WinRM · LOLBins

> **Exam anchors:** `find / -perm -4000` (Linux SUID), `sudo -l` (sudo abuse), **unquoted service path** (classic Windows privesc), **GTFOBins** = Linux / **LOLBAS** = Windows.

4.5 Web application attacks ★ heaviest sub-area

The largest slice of Domain 4 — anchor to the **OWASP Top 10**. **Burp Suite** is the through-line tool. Master the injection family and access-control flaws first.

Attack	What it is	Tool(s)	Indicator	Remediation
SQL injection	Inject SQL via input (union/error/blind/time-based).	sqlmap, Burp	DB errors, extracted rows, time delays.	Parameterized queries; least-priv DB user.
Command injection	Input reaches an OS shell → arbitrary commands.	Burp, commix	Command output in response.	Avoid shell calls; validate input.
XSS	Inject script into pages (stored/reflected/DOM).	Burp, XSStrike	Your JS runs in the victim's browser.	Output encoding, CSP, validation.
SSTI	Inject template syntax the engine evaluates → RCE.	tplmap, Burp	Expression evaluates in output.	Sandbox templates; no user input to engine.
Directory traversal	`../` to read files outside the web root.	Burp, Wfuzz	Contents of `/etc/passwd` etc.	Canonicalize paths, allowlist.
File inclusion (LFI/RFI/web shell)	Include local/remote files or upload a shell for execution.	Burp, Wfuzz	Remote/local file executes.	Disable remote include; validate uploads; no execute dir.
SSRF	Make the server fetch an attacker URL (often cloud metadata).	Burp, Gopherus	Server reaches internal resources.	Egress allowlist, block link-local, validate URLs.
CSRF	Force a logged-in victim's browser to send an unwanted request.	Burp CSRF PoC	State change with no valid token.	Anti-CSRF tokens, SameSite cookies.
IDOR	Change an identifier to access others' objects.	Burp	Another user's data returned.	Per-object server-side authorization.
Deserialization	Feed crafted serialized objects → code execution.	ysoserial, Burp	Code runs on object parse.	Don't deserialize untrusted data; integrity checks.
Session hijacking	Steal/predict/fixate a session identifier.	Burp	Access via another user's session.	Regenerate session on login, secure cookies.

Attack	What it is	Tool(s)	Indicator	Remediation
JWT manipulation	Tamper with token (alg=none, weak key, claim edits).	Burp, jwt_tool	Forged token accepted.	Verify signature/alg, strong keys, expiry.
API abuse	BOLA/IDOR, mass assignment, excessive data exposure.	Burp, Postman	Unauthorized objects/fields returned.	Per-object authz, schema validation, rate limits.
Collision attack	Two inputs with the same hash to defeat weak integrity/auth.	hashcat (concept)	Forged data matches a valid hash.	Use strong collision-resistant hashes (SHA-256+).
Brute-force / ACE	Guess creds/tokens; chain flaws to arbitrary code execution.	Burp Intruder, WPScan	Auth success / code runs.	Lockout, MFA, patch, input handling.

4.5 official tools: TruffleHog | Burp Suite | ZAP | Postman | sqlmap | Gobuster/DirBuster | Wfuzz | WPScan

> **Distractor watch:** stored vs reflected vs DOM XSS; and **parameterized queries** (not "WAF" or "input validation") as the *best* SQLi fix.

4.6 Cloud-based attacks

Mostly **misconfiguration and identity**, not memory corruption. Signature move: SSRF an app into the **instance metadata service** to steal role credentials.

Attack	What it is	Tool(s)	Indicator	Remediation
Metadata service attack	SSRF to `169.254.169.254` to steal instance creds.	Burp, curl	Temporary cloud creds returned.	Enforce IMDSv2; block link-local egress.
IAM misconfiguration	Over-permissive roles/policies enable escalation.	Pacu, Prowler, ScoutSuite	Escalation path (e.g., `iam:PassRole`).	Least privilege, remove wildcards, review roles.
Exposed storage buckets	Public/writable object storage.	ScoutSuite, cloud tools	Listable/writable bucket.	Block public access, tighten policies, encrypt.
Public access to services	Management ports/consoles exposed to the internet.	Nmap, cloud tools	Reachable admin endpoints.	Restrict via SG/NACL, private endpoints.
Trust relationship abuse	Assume roles across accounts via loose trust policies.	Pacu	Cross-account access gained.	Tighten role trust, condition keys, external IDs.
Container escape	Break out of a container to the host.	Kube-hunter, amicontained	Host access from a container.	Drop capabilities, no privileged mode, isolation.

Attack	What it is	Tool(s)	Indicator	Remediation
Workload runtime attack	Attack running containers/pods/functions.	Kube-hunter, kubectl	Compromise of live workload.	Admission control, runtime security, RBAC.
Image / artifact tampering	Poison a container image or build artifact.	Docker Bench	Malicious layer in a deployed image.	Signed images, registry scanning, provenance.
Supply chain attack	Compromise a dependency or pipeline component.	Trivy/Grype (concept)	Malicious dependency pulled in.	SBOM, pinning, dependency scanning.
Third-party integration / logging exposure	Leaky integrations or logs revealing secrets.	Manual, cloud tools	Secrets/keys found in logs/integrations.	Scrub logs, scope integration perms, rotate.

4.6 official tools: Pacu · Docker Bench · Kube-hunter · Prowler · ScoutSuite · Cloud-native vendor tools

---

4.7 Wireless attacks

Mostly the **Aircrack-ng** workflow (monitor → capture → deauth → crack) plus the rogue-AP family.

Attack	What it is	Tool(s)	Indicator	Remediation
Wardriving	Map wireless networks while moving.	Kismet, WiGLE.net, InSSIDer	Inventory of nearby SSIDs/BSSIDs.	Reduce signal leakage; hidden ≠ secure, so use WPA3.
Deauthentication	Spoofed deauth frames force a re-handshake (also DoS).	Aircrack-ng (aireplay-ng)	Clients drop and reconnect.	802.11w (Protected Management Frames).
Evil twin	Clone a legit SSID to lure clients/capture creds.	WiFi-Pumpkin, Airgeddon	Clients associate to your AP.	802.1X/EAP-TLS, WIDS, verify BSSIDs.
Captive portal	Fake login portal to harvest credentials.	WiFi-Pumpkin, Wifiphisher	Submitted portal credentials.	Client validation, disable auto-join.
WPS PIN attack	Brute-force/Pixie-Dust the WPS PIN to recover the PSK.	Reaver, Bully	PIN and PSK recovered.	Disable WPS.
Signal jamming	Flood RF to deny wireless service.	SDR, jammer (concept)	Loss of connectivity.	Spectrum monitoring; note legality.
Protocol fuzzing / packet crafting	Malformed frames to find flaws or spoof.	Scapy	Crash/unexpected AP behavior.	Patch firmware, robust parsing.
WPAD abuse	Answer Web Proxy Auto-Discovery to MITM traffic.	Responder	Clients use attacker proxy.	Disable WPAD; explicit proxy config.

4.7 official tools: WPAD · WiFi-Pumpkin · Aircrack-ng · WiGLE.net · InSSIDer · Kismet

Core Aircrack-ng workflow

```
airmon-ng start wlan0                    # monitor mode
airodump-ng wlan0mon                     # find BSSID + channel
airodump-ng -c 6 --bssid AA:.. -w cap wlan0mon
aireplay-ng --deauth 5 -a AA:.. wlan0mon  # force handshake
aircrack-ng -w wordlist.txt cap.cap      # crack PSK offline
```

4.8 Social engineering attacks

Targeting **people**. Know the delivery channel for each term and the physical-intrusion set.

Attack	What it is	Tool(s)	Indicator	Remediation
Phishing	Deceptive email to trick action/creds.	Gophish, SET	Clicks / submitted creds.	Training, filtering, DMARC, MFA.
Spearphishing / whaling	Targeted phishing; whaling = executives.	Gophish, Evilginx	Targeted victim compromised.	Exec awareness, verification, MFA.
Vishing / smishing	Phishing by phone call / SMS.	SET, spoofing	Info/action given by phone/text.	Callback verification procedures.
Impersonation / pretexting	False identity/scenario to build trust.	OSINT (Maltego, Recon-ng, theHarvester)	Target complies with false premise.	Identity verification, need-to-know.
Watering hole	Compromise a site the target group frequents.	BeEF	Victims infected via trusted site.	Patching, egress filtering, EDR.
Credential harvesting	Cloned login pages to capture creds.	SET, Evilginx (MFA-phish)	Captured credentials/session.	Phishing-resistant MFA (FIDO2), training.
Tailgating / shoulder surfing	Follow someone through a door / watch input.	—	Unauthorized entry / observed data.	Mantraps, badge enforcement, privacy screens.
Dumpster diving / eavesdropping / surveillance	Recover info from trash, listening, or watching.	—	Sensitive data recovered/overheard.	Shredding, clean-desk, physical controls.

4.8 official tools: SET · Gophish · Evilginx · theHarvester · Maltego · Recon-ng · BeEF

4.9 Attacks against specialized systems

An "explain" objective — recognition level. Know the platform, its signature weakness, and a tool or two. OT/ICS demands extra caution (safety-critical, fragile).

Attack	What it is	Tool(s)	Indicator	Remediation
Mobile: info disclosure	Secrets/data exposed in app storage or traffic.	MobSF, Drozer, ADB	Keys/data extracted from app.	Encrypt storage, cert pinning, no embedded secrets.

Attack	What it is	Tool(s)	Indicator	Remediation
Mobile: jailbreak/rooting	Remove OS restrictions to gain full control.	ADB, Frida	Root/jailbreak achieved.	Root/jailbreak detection, attestation.
Mobile: permission abuse	Over-broad app permissions misused.	MobSF, Drozer	App accesses beyond its need.	Least-privilege permissions, review.
AI: prompt injection	Malicious input overrides model instructions.	Manual prompt testing	Model ignores guardrails / leaks data.	Input/output filtering, guardrails, least-priv tools.
AI: model manipulation	Poison training data or extract/evade the model.	Manual	Skewed outputs / model leakage.	Data governance, monitoring, access control.
OT: register manipulation	Alter PLC registers to change physical process.	Modbus tools	Unauthorized PLC state change.	Segmentation, read-only access, monitoring.
OT: Modbus / CAN bus / replay / plaintext	Abuse unauthenticated industrial/automotive protocols.	Scapy, tcprelay	Injected/replayed control frames.	Segmentation, unidirectional gateways, careful testing.
NFC / RFID	Clone or relay contactless credentials.	Proxmark3, Flipper	Cloned badge/tag works.	Encrypted/rolling creds, MFA at doors.
Bluejacking / Bluetooth spamming	Send unsolicited messages/floods over Bluetooth.	Bluestrike	Spam/pairing prompts on devices.	Non-discoverable, patch, disable when unused.

4.9 official tools: Scapy · tcprelay · Wireshark/tcpdump · MobSF · Frida · Drozer · ADB · Bluestrike

OT/ICS caution is testable: these systems are safety-critical and fragile, so the exam-correct approach favors passive techniques, tight scope, and care over aggressive scanning.

4.10 Use scripting to automate attacks

Recognize the language, its attack libraries/tools, and the Breach-and-Attack-Simulation platforms. You won't write much from scratch — you'll read and pick.

Language / category	What it's used for	Key tools / notes
PowerShell	Windows/AD post-exploitation and automation.	PowerSploit, PowerView, PowerUpSQL, AD search.
Bash	Linux glue: input/output management, data manipulation.	Pipe/redirect, loops, `grep` / `awk` / `sed`.
Python	Cross-platform tooling and protocol work.	Impacket (SMB/Kerberos), Scapy (packet crafting).
Breach & Attack Simulation (BAS)	Automate/emulate adversary techniques at scale.	Caldera, Infection Monkey, Atomic Red Team.

Tie-in to Domain 2.3/3.2: the same logic constructs (loops, conditionals, boolean/string/arithmetic operators) and use

of libraries/functions/classes are tested across recon, validation, and here for attack automation.

→ How to use this guide

- **One objective (4.x) per session.** Learn every row via the chain, then move on — don't grind the whole 35% linearly.
- **Turn each row into an Anki card:** prompt with the attack, recall tool → indicator → remediation. Let spaced repetition resurface misses.
- **Do it, don't just read it:** PortSwigger Web Security Academy (4.5), TryHackMe/HackTheBox, and the CompTIA labs convert trivia into memory.
- **Drill the compare-contrast pairs:** Kerberoasting vs AS-REP roasting, stored vs reflected XSS, CVE vs CWE vs CVSS vs EPSS, reverse vs bind shell, PtH vs PtT vs pass-the-token.
- **Weight your hours by the blueprint:** 4.5 (web) and 4.3 (auth) are the densest; give them the most reps.

Authorized use only. Every technique here is for penetration testing within a defined scope and signed rules of engagement. Running these against systems you don't own or aren't authorized to test is illegal. As a tester you document what you did (for cleanup) and pair each finding with the remediation shown above.

CompTIA PenTest+ PT0-003 (Objectives v3.0) · Domain 4 (Attacks & Exploits, 35%) · Objectives 4.1–4.10 mapped to the chain framework: what it is → tool → indicator → remediation. Bulleted objective lists are non-exhaustive per CompTIA; other examples may appear on the exam.